Usama Arshad.

OFFENSIVE SECURITY LEAD · RED TEAM · FINTECH & CLOUD

Riyadh, Saudi Arabia
+966 56 913 7225
gusama21@gmail.com
usamaarshad.me

GitHub github.com/usama0x01 · **LinkedIn** in/usama0x01 · **X** @usama0x01 · **Bugcrowd** Xam_3xPloiTeR · **Synack SRT** usama-arshad · **Medium** @usama0x01

Profile

OSCP-certified Offensive Security Lead with **9+ years** across red team, application security, and cloud — spanning web, mobile, API, GCP, AWS, and Kubernetes. Currently leads the offensive security function at **Tabby**, MENA's largest BNPL fintech (**14M+ users**), where I build autonomous VAPT pipelines, embed AppSec gates into GitLab CI/CD, and harden GKE workloads. **80+ engagements** delivered for Fortune 500 companies and SAMA-regulated financial institutions — alongside a standing vulnerability-research practice: **8 published CVEs** and an active WordPress disclosure pipeline that turns exploitation chains into decisions executives can act on.

Vulnerability Research & Disclosure

8 CVEs published · **59+** reported to WPScan · **121+** queued for review · peaked at **13th (Top-15)** on the WPScan researcher leaderboard

FLAGSHIP **CheckView** **CVE-2026-18786** CVSS 8.8 · HIGH · UNAUTHENTICATED · FIXED 2.3.2 · PUBLISHED 2026-08-07

Unauthenticated administrator-account creation via a REST API authentication bypass in the CheckView WordPress plugin (fixed in 2.3.2) — full site takeover from a single unauthenticated request. Original discovery and coordinated disclosure; verified & published by WPScan.

ADVISORY WPSCAN · CREDIT **ORIGINAL RESEARCHER — USAMA ARSHAD**

PUBLISHED DISCLOSURES — TOP BY CVSS

7.5 · High	Ezoic — Unauthenticated database export via content-export REST routes	CVE-2026-18789 · UNAUTHENTICATED · FIXED 2.23.1 · 2026-08-10
6.5 · Med	WP Travel Engine — Unauthenticated booking-details disclosure & modification	CVE-2026-16737 · UNAUTHENTICATED · FIXED 6.8.5 · 2026-08-10
6.1 · Med	Interactive World Maps — Reflected Cross-Site Scripting (CWE-79)	CVE-2024-3681 · UNAUTHENTICATED (UI:R) · ≤ 2.4.14 · NVD / MITRE / WORDFENCE
5.3 · Med	GeoDirectory — Unauthenticated pending/draft listing disclosure via markers REST endpoint	CVE-2026-16988 · UNAUTHENTICATED · FIXED 2.8.169 · 2026-08-03

+3 more published CVEs — MStore API (CVE-2026-16041 · 5.3), Salon Booking System (CVE-2026-17022 · 5.3), Events Manager (CVE-2026-18050 · 3.7). Full log: usamaarshad.me/research

Findings are reproduced in a local WordPress lab, deduplicated against the NVD / Patchstack catalogue, and reported through WPScan under coordinated disclosure. The 8 above are patched, credited, and public; the remaining reported findings and 121+ queued items stay embargoed — described by class only — until fixes ship and CVE IDs are assigned. Leaderboard: **peaked at 13th (Top-15)** on the WPScan researcher board, a rolling window currently showing 15th. Full disclosure log: usamaarshad.me/research

Experience

Offensive Security Lead

JUN 2025 — PRESENT · CURRENT

Tabby · MENA's largest BNPL fintech · Riyadh, Saudi Arabia

- Lead the offensive security function for **14M+ users**: red team, AppSec, and cloud security across web, mobile, API, GCP, and GKE.
- Architected autonomous VAPT dashboards with Jira / tracker automation — **cut assessment cycle time 60%** and eliminated manual reporting.
- Run continuous red team and adversary simulations, surfacing real-world attack chains before release.
- Embedded SAST, DAST, secret scanning, and container scanning into GitLab CI/CD, gating insecure releases at merge time.
- Hardened GKE workloads via Workload Identity, network policies, admission controllers, and runtime detection.

ISM Consultant & Team Lead

AUG 2024 — MAY 2025

SecurEyes · Riyadh, Saudi Arabia

- Led large-scale **SAMA** fintech security assessments for major Saudi financial institutions: end-to-end VAPT, source code review, red team.
- Full-scope red team operations: external / internal infrastructure, web, mobile, API, Active Directory, WiFi, physical, cloud, DLP/EDR evasion.
- Mentored consultants, reviewed deliverables, and presented findings to executives and regulators.

Senior Security Engineer

DEC 2021 — JUL 2024

Ebryx · Lahore, Pakistan

- Delivered **80+ offensive engagements** for Fortune 500 clients: pentesting, source code review, red teaming.
- Led a sub-team of consultants; owned scoping, execution, peer review, and report quality.
- Translated complex exploitation chains into business-impact narratives for executives.

Red Team Member

MAR 2021 — PRESENT · PART-TIME

Synack Red Team · Remote

- Continuous vulnerability discovery and exploitation on private enterprise targets.
- High-impact findings: IDOR, BOLA, authentication bypass, and business-logic flaws.

Penetration Tester

MAR 2018 — MAY 2021

Security Wall · Lahore, Pakistan

- Validated vulnerabilities across **50+ engagements** spanning web, mobile, and network.
- Built reusable internal tooling and methodologies that raised team throughput.

Areas of Expertise

01 RED TEAM & ADVERSARY SIMULATION

MITRE ATT&CK · Purple Team · Physical Intrusion · OSINT · Cobalt Strike · Sliver · Mythic · Initial Access · Lateral Movement · Persistence · Defense Evasion

02 OFFENSIVE TESTING

Web / OWASP Top 10 · Mobile / MASVS · iOS & Android · REST · GraphQL · gRPC · Network & Infrastructure · Active Directory · WiFi · Thick Client · Source Code Review

03 CLOUD & CONTAINER SECURITY

GCP · AWS · GKE / Kubernetes · Container Escape · IAM Privilege Escalation · Metadata Abuse · Workload Identity · Terraform IaC Scanning · CIS Benchmarks

04 APPSEC & DEVSECOPS

GitLab CI/CD Security Gates · SAST · DAST · SCA · Secret Scanning · Threat Modeling / STRIDE · Secure SDLC · Code Review — Python / Go / Node / Java

05 TOOLING & AUTOMATION

Burp Suite Pro · Frida · Ghidra · IDA · Nmap · Nuclei · Nessus · Metasploit · BloodHound · Sliver · FFUF · Sqlmap · Wireshark · Custom Python & Go

06 COMPLIANCE & FRAMEWORKS

SAMA CSF · PCI DSS · ISO 27001 · OWASP ASVS · NIST CSF

Achievements

8 Published CVEs — WordPress Plugin Security

2024 · 2026

Flagship **CVE-2026-18786** (CheckView, CVSS 8.8) — plus Ezoic, WP Travel Engine, Interactive World Maps, GeoDirectory, MStore API, Salon Booking System & Events Manager; all patched and credited. Peaked at 13th (Top-15) on the WPScan researcher leaderboard.

BlackHat MEA CTF — Finalist

2023 · 2024

Top 32 (2023) and Top 29 (2024) of 250+ teams globally, representing Pakistan.

National CTF Hat-Trick

2021 — 2023

Podium finishes at Pakistan's national cyber hackathon three consecutive years — awarded by the President, the Prime Minister, and the IT Minister.

Four Halls of Fame

×4

Responsible-disclosure recognition from the **United Nations**, **Walmart**, **Achmea**, and **The Sun**.

Speaker

ONGOING

Recurring talks at universities and security conferences on offensive security and AI-driven attack automation.

Certifications & Education

OSCP Offensive Security Certified Professional
OFFENSIVE SECURITY

HTB Offshore Pro Lab — Active Directory & banking infrastructure
HACK THE BOX

PEH Practical Ethical Hacker
TCM SECURITY

CNSS Certified Network Security Specialist
ICSI

EDUCATION

BSc Computer Science
COMSATS University, Lahore · 2018 — 2021

LANGUAGES

English — Professional · **Urdu** — Native

USAMA ARSHAD · OFFENSIVE SECURITY LEAD
GUSAMA21@GMAIL.COM · USAMAARSHAD.ME
REFERENCES & FULL DISCLOSURE LOG ON REQUEST